

CYBERSECURITY-LABS

INFORMATION SECURITY

LAB REPORT



Desarrollo Políticas Seguridad Recurso Humano

Informe de práctica

Víctor José Santos Guzmán

Information Security

Cybersecurity / Cloud / Networks / GRC



Introducción

Como parte de la auditoría realizada a la empresa Xyber IT, pude identificar diversas debilidades relacionadas con la gestión de los recursos humanos y la seguridad de la información. Entre las principales debilidades encontradas se destacan el intercambio de contraseñas entre usuarios, la ausencia de capacitaciones de seguridad, la falta de políticas organizativas formales y la inexistencia de procesos definidos para situaciones de emergencia o cambios de personal.

Con el objetivo de fortalecer la seguridad de la información dentro de la organización, propongo las siguientes políticas de seguridad ligadas a los recursos humanos.

Política General de Seguridad de Recursos Humanos

Enunciado de la política

Establecer lineamientos y controles que permitan garantizar que todos los empleados, contratistas y personal temporal comprendan y cumplan sus responsabilidades relacionadas con la seguridad de la información antes, durante y después de su relación laboral con la empresa Xyber IT.

Objetivos de la política

- Proteger la confidencialidad, integridad y disponibilidad de la información.
- Reducir los riesgos derivados del factor humano.
- Definir responsabilidades de seguridad para todos los colaboradores.
- Garantizar el uso adecuado de los sistemas de información.
- Promover una cultura organizacional orientada a la seguridad.

Alcance

Esta política aplica a todos los empleados, contratistas, consultores, personal temporal y terceros que tengan acceso a los sistemas de información de la empresa Xyber IT.

Responsable

La responsabilidad principal recae sobre el Departamento de Recursos Humanos en conjunto con el Encargado de Seguridad y el Departamento de Tecnología.

Categoría de la política

Aplica antes de la contratación, durante la relación laboral y después del cese o cambio de funciones.

Sus políticas propuestas

1. Política de verificación de antecedentes

Categoría: Antes de la contratación.

Antes de contratar a cualquier empleado, Recursos Humanos deberá realizar una validación de referencias laborales y profesionales con el fin de reducir riesgos de seguridad.

2. Política de acuerdos de confidencialidad

Categoría: Antes de la contratación.

Todo empleado deberá firmar un acuerdo de confidencialidad donde se comprometa a proteger la información de la organización incluso después de finalizar la relación laboral.

3. Política de asignación de accesos

Categoría: Durante la relación laboral.

Los accesos a sistemas, aplicaciones y bases de datos serán asignados únicamente de acuerdo con las funciones y responsabilidades del puesto.

4. Política de uso de contraseñas

Categoría: Durante la relación laboral. Las contraseñas son personales e intransferibles. Queda

prohibido compartir credenciales entre usuarios. Las contraseñas deberán cumplir requisitos mínimos de complejidad y renovación periódica.

5. Política de capacitación en seguridad

Categoría: Durante la relación laboral.

Todos los empleados deberán participar en programas periódicos de capacitación y concienciación sobre seguridad de la información, incluyendo temas como phishing, ingeniería social y buenas prácticas.

6. Política de responsabilidades de seguridad

Categoría: Durante la relación laboral.

Cada colaborador será responsable del adecuado uso de los recursos tecnológicos asignados y deberá cumplir las políticas y procedimientos establecidos por la organización.

7. Política de gestión de cambios de puesto

Categoría: Durante la relación laboral.

Cuando un empleado cambie de posición dentro de la empresa, sus privilegios de acceso deberán ser revisados, modificados o eliminados según sus nuevas responsabilidades.

8. Política de reporte de incidentes

Categoría: Durante la relación laboral.

Todo empleado deberá reportar inmediatamente cualquier incidente o sospecha relacionada con la seguridad de la información al Encargado de Seguridad.

9. Política de revocación de accesos

Categoría: Después del cese o cambio de trabajo.

Cuando un empleado finalice su relación laboral, todos sus accesos a sistemas, aplicaciones, correo electrónico y recursos tecnológicos deberán ser revocados de manera inmediata.

10. Política de devolución de activos

Categoría: Después del cese o cambio de trabajo.

Todo empleado que deje la organización deberá devolver equipos informáticos, dispositivos móviles, credenciales, documentos y cualquier otro activo propiedad de la empresa.

11. Política de segregación de funciones

Categoría: Durante la relación laboral.

Las actividades críticas deberán distribuirse entre diferentes personas para reducir riesgos de fraude, errores o accesos no autorizados.

12. Política de sanciones disciplinarias

Categoría: Durante la relación laboral.

El incumplimiento de las políticas de seguridad podrá generar medidas disciplinarias conforme a las normas internas de la organización.

Revisión de la política

La presente política deberá revisarse al menos una vez al año o cuando ocurran cambios importantes en la infraestructura tecnológica, procesos organizacionales, requisitos legales o incidentes de seguridad significativos. La revisión será responsabilidad conjunta del Departamento de Recursos Humanos, el Encargado de Seguridad y la Gerencia General.